DBMS 보안 점검 가이드

Oracle, MSSQL, Altibase, Tibero 등 주요 DBMS 환경에서의 접근 관리 및 옵션 관리 보안 점검 항목과 조치 방법을 정리한 기술 가이드입니다.

DBMS 보안

접근 관리 · 옵션 관리

ADMIN_RESTRICTIONS_LISTENER 설정 (D-16)

접근 관리

listener.ora 파일에 `ADMIN_RESTRICTIONS_{listener name}=ON` 라인을 추가한 후, listener를 재실행하거나 `lsnrctl reload` 명령어로 재로딩합니다.

```
# listener.ora 설정 예시
PASSWORDS_LISTENER = D15240A9838844B
ADMIN_RESTRICTIONS_LISTENER = ON
```

이 설정을 통해 리스너에 대한 원격 관리 명령을 차단하여 비인가 접근을 방지합니다.

Windows 인증 모드 사용 (D-17)

MSSQL · 접근 관리

보안 위협

혼합 인증 모드 사용 + sa 계정 활성화 시, 잘 알려진 sa 계정에 대한 **계정 추측 공격** 위험 존재

권고 사항

- Windows 인증 모드 사용 권고 (Kerberos 프로토콜 기반)
- sa 계정은 꼭 필요하지 않은 경우 **비활성화**
- 활성화 시 반드시 강력한 암호 정책 적용

Windows 인증 모드 활성화 방법

SQL Server Management Studio에서 해당 서버 우클릭 → 속성 → 보안 → 서버 인증 → **Windows 인증 모드(W)** 선택

양호 기준: Windows 인증 모드 사용 + sa 계정 비활성화 (또는 강력한 암호 정책 적용)

Audit Table 접근 권한 제한 (D-18)

옵션 관리

ORACLE · ALTIBASE · TIBERO

Audit Table 접근 권한을 **관리자 계정으로만 제한**하여 비인가자의 감사 데이터 수정·삭제를 방지하고 감사 기록의 무결성과 신뢰성을 보장합니다.

Oracle / Tibero

DBA_TABLES에서 AUD$ 소유자 확인 후 불필요 계정 권한 삭제

```
REVOKE <권한> ON <Object> FROM <계정명>;
```

Altibase

sys_users, sys_tables 조회로 AUDIT 테이블 확인 후 불필요 권한 회수

```
REVOKE <권한> ON [audit_table] FROM [계정명];
```

Tibero (OS 파일)

AUDIT_TRAIL=OS 설정 시 감사 파일 디렉터리에 일반 사용자 접근 차단 필수

```
AUDIT_FILE_DEST=/home/Tibero/audit/
AUDIT_FILE_SIZE=10M
```

Public Role 설정 제한 (D-19)

옵션 관리 · 상

응용 프로그램 또는 DBA 계정의 Role이 **Public으로 설정된 경우**, 일반 계정에서도 중요 테이블에 접근 가능하여 정보 유출 위험이 존재합니다.

Oracle DB

```
SELECT granted_role FROM
dba_role_privs
WHERE grantee = 'PUBLIC';
REVOKE [Role name] FROM PUBLIC;
```

Altibase

sys_grant_object, sys_grant_system 조회 → GRANTEE_ID가 "0"인 경우 Public 권한 부여 의미 → 즉시 회수

```
REVOKE <권한> ON <Object> FROM
[계정명];
```

Tibero

```
SELECT * FROM dba_role_privs;
SELECT * FROM user_role_privs;
REVOKE <권한> FROM [계정명];
```

⚠ 취약 기준: DBA 계정의 Role이 Public으로 설정된 경우

OS 인증 파라미터 FALSE 설정 (D-19)

ORACLE DB · 옵션 관리 · 상

OS_ROLES = FALSE

TRUE 설정 시 OS 그룹에 의해 GRANT된 권한이 허락되어 악의적 사용자의 시스템 권한 악용 위험

REMOTE_OS_AUTHENT = FALSE

TRUE 설정 시 신뢰하는 원격 호스트에서 인증 절차 없이 DB 접속 가능 → 중요 정보 유출 위험

REMOTE_OS_ROLES = FALSE

TRUE 설정 시 원격 사용자가 OS의 다른 사용자로 위장하여 DB 접근 가능 → 권한 상승 위험

버전 9 이후: DBMS Shutdown 시 spfile이 재생성되므로 SPFILE 재생성 필요

OS 인증 파라미터 점검 및 조치 방법

Oracle DB의 `init.ora` 파일에 아래 파라미터를 추가하고 인스턴스를 재시작합니다.

01

OS_ROLES 확인 및 조치

```
SQL> SHOW PARAMETER os_roles;
# init.ora에 OS_ROLES = FALSE 추가 후 재시작
```

02

REMOTE_OS_AUTHENT 확인 및 조치

```
SQL> SHOW PARAMETER remote_os_authent;
# init.ora에 remote_os_authent = FALSE 추가 후 재시작
```

03

REMOTE_OS_ROLES 확인 및 조치

```
SQL> SHOW PARAMETER remote_os_roles;
# init.ora에 remote_os_roles = FALSE 추가 후 재시작
```

비인가 Object Owner 제한 (D-20)

옵션 관리 · 하

ORACLE · ALTIBASE · TIBERO · POSTGRESQL

보안 위협

Object Owner가 **SYS, SYSTEM 및 관리자 계정 이외**의 일반 계정에 존재할 경우, 공격자가 Object 수정·삭제를 통해 중요 정보 유출 및 변경 가능

※ Object: ALTER, DELETE, EXECUTE, INDEX, INSERT, SELECT 등

점검 및 조치 (Oracle DB)

```
-- 비인가 Owner 확인
SELECT DISTINCT owner FROM dba_objects
WHERE owner NOT IN
('SYS','SYSTEM','OUTLN','PUBLIC',...)
AND owner NOT IN
(SELECT grantee FROM dba_role_privs
WHERE granted_role = 'DBA');

-- 권한 취소
REVOKE <권한> ON <Object> FROM user;
```

양호 기준: Object Owner가 SYS, SYSTEM, 관리자 계정으로만 제한된 경우

보안 점검 항목 요약

항목	대상 DBMS	등급	핵심 조치
ADMIN_RESTRICTIONS_LISTENER	Oracle	하	listener.ora에 ON 설정
Windows 인증 모드	MSSQL	하	Windows 인증 모드 활성화, sa 비활성화
Audit Table 접근 제한	Oracle, Altibase, Tibero	상	관리자 계정으로만 접근 제한
Public Role 제한	Oracle, Altibase, Tibero, Cubrid	상	PUBLIC 그룹 권한 취소
OS 인증 파라미터 FALSE	Oracle	상	OS_ROLES 등 3개 파라미터 FALSE
Object Owner 제한	Oracle, Altibase, Tibero, PostgreSQL	하	SYS/SYSTEM/관리자 계정으로 제한